

WEB APPLICATION VULNERABILITY ASSESSMENT REPORT

Target: OWASP Juice Shop (localhost:3000)

AUGUST 24, 2026

Assessor: Anil Kashyap

Executive Summary

- Overview: Testing revealed multiple high and medium-severity vulnerabilities within the application's core functionality.
- Impact: Attackers can bypass authentication, steal user sessions via XSS, view unauthorized shopping cart data, and access confidential internal files.
- Recommendation: Immediate remediation focusing on input validation, secure session management, and server-side access controls is strongly advised.

High-Risk Findings

- **1. SQL Injection (Authentication Bypass)**
 - Description: The login endpoint fails to sanitize input, allowing attackers to inject SQL commands (' OR 1=1 --) and bypass authentication, gaining administrative access.
 - Fix: Implement parameterized queries and an ORM.
- **2. Broken Authentication (Security Questions)**
 - Description: Password reset mechanisms rely on predictable or brute-forceable security questions (e.g., guessing "Stop'n'Drop" for Bender).
 - Fix: Implement *secure, time-limited email reset tokens and enforce MFA.*

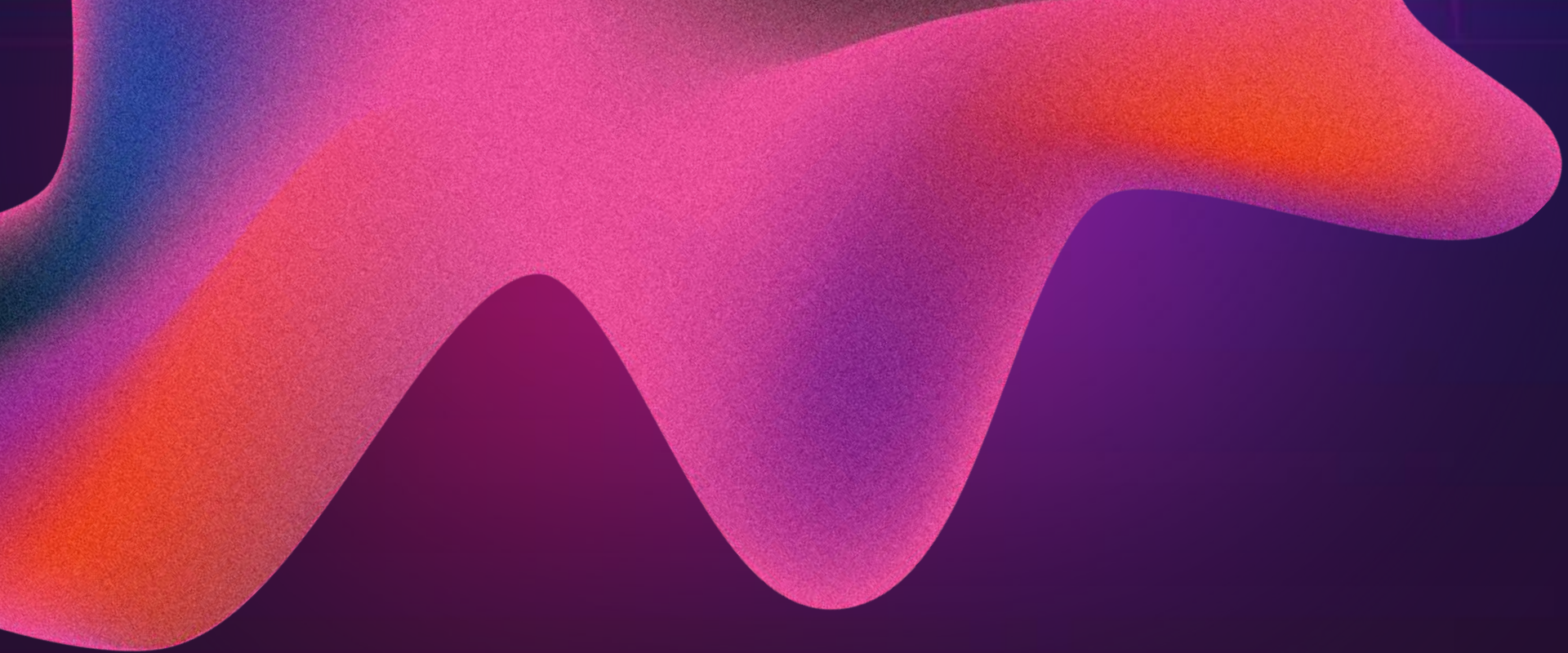
Medium-Risk Findings

3. Insecure Direct Object Reference (IDOR)

- Description: Shopping baskets are tracked via a predictable client-side integer (bid). Manipulating this value allows viewing other users' baskets.
- Fix: Validate session ownership on the server backend before serving basket data.

4. DOM-based XSS

- Description: The search parameter reflects raw HTML into the DOM without sanitization, allowing arbitrary JavaScript execution via payload `<iframe src="javascript:alert('xss-Exploited')">`.
- Fix: Implement context-aware output encoding and strict Content Security Policies.



Medium/Low-Risk Findings

5. Sensitive Directory Exposure

- Description: The /ftp/ directory is publicly accessible, exposing backup files and markdown documents.
- Fix: Disable directory browsing and restrict access to internal storage paths.

6. Missing Security Headers

- Description: Passive ZAP analysis revealed missing CSP and Anti-Clickjacking headers.
- Fix: Configure the server to return standard defensive HTTP headers.

Conclusion & Strategic Roadmap

Overall Posture: HIGH RISK

Critical flaws in authentication and access control expose the platform to immediate account takeovers and data breaches.

Actionable Roadmap:

Phase 1 (Immediate):

Patch SQL Injection on the login page and replace insecure security questions with secure password reset tokens.

Phase 2 (Short-Term):

Enforce server-side verification for shopping baskets (IDOR), sanitize search inputs (DOM XSS), and lock down the exposed /ftp/ directory.

Phase 3 (Ongoing):

Implement missing HTTP security headers (CSP) and schedule a follow-up assessment to verify all patches.



THANK YOU

[Linked In](#)

[GitHub](#)